Higher National Diploma in Network Engineering, Year 2
BSc (Hons) Ethical Hacking & Network Security, Year 2

PRINCIPLES OF INFORMATION SECURITY

Email and databases



Day 7 - Morning

Running case: Taxila College, a fictional college

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management

Today

Why email cannot prove its sender, and who can read the SIS.

- How email travels - 35 min
- Three checks that fight spoofing - 30 min
- Reading a header - 30 min
- Least privilege for a database - 30 min
- At rest, in transit, and a controller's duty - 30 min



Today serves one outcome

LO1 Explain the fundamentals of information security.

LO2 Discuss the key characteristics of cryptography and cryptographic systems.

LO3 Analyze the principles of encryption, decryption, hashing, and data integrity.

LO4 Outline the process of ensuring digital security.

LO5 Describe the fundamentals of threats and countermeasures.

LO6 Explain the fundamentals and process of business continuity planning.

Where we start

RECALL

You sign with the private key and verify with the public key.

- **Least privilege** is the minimum access an account needs
- **Accounting** is the record of what was done
- Today: the same ideas, applied to **mail** and to a **database**

A signature proves origin. A scoped account limits damage. A log shows what happened.

The message from "the Registrar"

- Several staff got an email that seemed to come from the **Registrar**
- It asked them to update their **bank details** through a link
- **Two** people did

If someone did get a password, what could it reach?

T TAXILA

Mail from taxila.example that can be checked, and an SIS account that reaches only what it needs.

DPO

DATA PROTECTION OFFICER

If someone did get a password, what could it reach in the SIS, and would we know?

The Data Protection Officer, on the seventh day of your placement.

CONCEPT 1

How email travels

The fake message from the Registrar used exactly this gap.

TRY IT FIRST

Mail as a postcard through relays, with a writable from line.

35 min

Demonstration: the postcard through the relays

1. Choose the Registrar's real address as the from line
2. Hand the message to each server in turn
3. Read what each relay checked
4. Start again with a look-alike from line

Every from line arrives the same way.

Mail is handed from relay to relay

- Servers pass mail on by **SMTP**, the Simple Mail Transfer Protocol
- Each relay adds a **received line** at the top
- The **sender writes** the from line
- No relay is required to **check** it

Writing someone else's address is as easy as writing your own.

Harm that uses the same gap

Bait	Aimed	Trust
Phishing Tricks people into giving a password, money or data, often by a link. *"Update your bank details here."*	**Spear-phishing** Phishing aimed at one person or a small group, with details about them. *Names last week's fee deadline.*	**Business email compromise** Seems to come from a manager or supplier; asks for a payment. *"Pay this invoice to the new account."*

All three rely on **spoofing**: a from line naming someone who did not send it.

A postcard through the sorting offices

YOU ALREADY KNOW THIS

A postcard passes through several sorting offices. Anyone can write the return address, and no office checks it.

MAPPING

the return address anyone can write = the from line · **no office checking it =** the missing sender check

T TAXILA

The fake message from the Registrar used exactly this gap.

× COMMON MISTAKE

The from line proves who sent the mail.

Anyone can write it; the three checks and the header tell the truth.

CONCEPT 2

Three checks that fight spoofing

The taxila.example domain publishes SPF, DKIM and DMARC so receivers can tell real mail from spoofed.

TRY IT FIRST

Three checks catch a spoofed message.

30 min

Demonstration: three checks

1. Deliver the spoofed message with nothing published
2. Turn on SPF, then DKIM, and deliver again
3. Publish DMARC with none, then quarantine
4. Deliver the look-alike message

Each check catches a different gap.

Three records a domain publishes

List	Seal	Rule
SPF Sender Policy Framework. The servers allowed to send for the domain. *Only 192.0.2.25 for taxila.example.*	**DKIM** DomainKeys Identified Mail. A signature checked with the domain's public key. *Key at mail._domainkey.*	**DMARC** The rule for failures, joined to the from line. *none, quarantine or reject.*

DMARC is Domain-based Message Authentication, Reporting and Conformance.

DKIM is Day 4's signing, applied to mail

RECALL

You sign with the private key and verify with the public key.

- Taxila's mail server **signs** with the domain's private key
- The receiver **verifies** with the published public key
- A spoofer outside Taxila holds **no** private key

DKIM signs; it does not encrypt.

What DMARC tells receivers

- The from line's domain must match a check that **passed**
- `none`: deliver, and send a report
- `quarantine`: hold it apart, as in a junk folder
- `reject`: refuse it

Publish SPF and DKIM before a strict DMARC policy.

A sender list, a wax seal and a rule

YOU ALREADY KNOW THIS

The post office keeps a list of who may post for each company. Each company seals its letters with its own seal. And each company leaves a rule for unsealed letters.

MAPPING

the sender list = SPF · **the wax seal** = the DKIM signature · **the rule for failures** = DMARC

T TAXILA

The taxila.example domain publishes SPF, DKIM and DMARC (register item 13).

Protecting the content itself

S/MIME

- Secure/Multipurpose Internet Mail Extensions
- Certificates from an **authority**
- Built into many work mail programs

PGP

- Pretty Good Privacy
- Keys vouched for by **people**
- Common among technical users

Both sign and encrypt one message, end to end. Overview only.

A look-alike passes its own checks

- Anyone can register `sis-taxila.example`
- It publishes its own **SPF, DKIM and DMARC**
- Its messages **pass**, for its own domain

The checks prove which domain sent it, not that the domain is honest.

× COMMON MISTAKE

SPF, DKIM and DMARC make phishing impossible.

A look-alike domain can pass its own checks.

CONCEPT 3

Reading a header

The fake message's headers would have shown an origin that was not Taxila.

TRY IT FIRST

Read the received lines bottom-up and spot the tells.

30 min

Demonstration: the header trail

1. Choose the quarantined message
2. Put the received lines in order, oldest first
3. Mark the lines that are tells
4. Repeat with the look-alike message

Read the received lines from the bottom up.

Three parts of a header a defender reads

- **Received lines**: bottom up; trust only your own server's
- **Authentication results**: what SPF, DKIM and DMARC found
- **From against reply-to**: where your answer would really go
- A **display name** proves nothing

The lowest line your own server wrote names the true origin.

Two "Registrar" messages, read side by side

Spoofed, and caught

From taxila.example, but spf=fail and dkim=none, so dmarc=fail. Held in quarantine.

× Look-alike, and delivered

From sis-taxila.example. All three checks pass for that domain. Delivered to the inbox.

Only a person reading the address catches it.

*The published checks stop **spoofing**. People must still read **the domain**.*

Stamps on a parcel

YOU ALREADY KNOW THIS

Each depot stamps a parcel, and each new stamp goes on top. To trace the journey you read from the oldest stamp, at the bottom, upwards.

MAPPING

the oldest stamp at the bottom = the first relay · **a return address one letter off** = a look-alike domain

T TAXILA

The fake message's headers would have shown an origin that was not Taxila.

× COMMON MISTAKE

A convincing display name proves the sender.

The sender types the display name, like the address.

CONCEPT 4

Least privilege for a database

The account the portal uses on the SIS must not be able to drop tables (register item 14).

TRY IT FIRST

A scoped account against an over-privileged one.

30 min

Demonstration: two accounts, one leaked password

1. Set the portal's account up with every right
2. Suppose its password leaks; count what it reaches
3. Scope it to the portal's job and repeat
4. Turn the query log off and look again

A stolen account reaches exactly what it was granted.

The portal's database account

Over-privileged

- `ALL PRIVILEGES ON *.*`
- Drops tables, reads other databases
- Makes **new accounts**

Scoped

- `SELECT` on `students`
- `SELECT, INSERT, UPDATE` on `grades`
- Everything else is **refused**

Granting is the database's form of authorisation.

Record who read or changed what

- **Auditing**: a log of who read or changed what
- The **general query log** records each statement as it arrives
- Refused requests are recorded too
- A scoped account also limits **injection**; its fix is a **parameterised query**

Least privilege prevents. The log detects.

The till key and the safe

YOU ALREADY KNOW THIS

In a shop, the till staff have a key that opens the till drawer, not the safe. A lost till key reaches one drawer.

MAPPING

the till key = a scoped account · **the master key =** full privileges · **keeping the master off the till =** least privilege

T TAXILA

The account the portal uses on the SIS must not be able to drop tables (register item 14).

× COMMON MISTAKE

The application needs full database rights to work.

It needs only the reads and writes its job requires.

CONCEPT 5

At rest, in transit, and a controller's duty

The Data Protection Officer asks whose data the SIS holds and who can read it.

TRY IT FIRST

Where encryption protects and where it does not.

30 min

Demonstration: where encryption protects

1. Turn on encryption at rest
2. Turn on encryption in transit
3. Read who can see the record in each place
4. Note the one place still readable

Each lock covers one place.

Three places personal data sits

At rest	In transit	In use
Disk and backup	**The network**	**A live query**
Encryption at rest; TDE does it under a running database.	Encryption in transit, such as TLS from Day 4.	The database decrypts for any account allowed to read.
A stolen backup shows ciphertext.	*A watcher sees only ciphertext.*	*Only grants and the log help.*

TDE is transparent data encryption: the application notices **nothing**.

Realistic data, without the real people

- **Masking**: realistic but false values, in the right format
- **Anonymising**: nobody can be identified from what is left
- Test systems are rarely guarded like the real one

This afternoon's `taxila-db` holds only invented rows.

DPO

DATA PROTECTION OFFICER

Whose data does the SIS hold, and who can read it?

The Data Protection Officer, on Taxila's duty as a controller.

A controller's duty

- The **controller** decides why and how personal data is processed
- It must keep the data **secure** and show what it does with it
- Sri Lanka's **Personal Data Protection Act**, No. 9 of 2022, as amended
- The EU's **GDPR** is the best-known law of the same kind

Taxila is the controller for its students' and staff's data.

A locked cabinet and an armoured van

YOU ALREADY KNOW THIS

A bank locks its files in a cabinet and moves money in an armoured van. A clerk allowed to read a file just opens it.

MAPPING

the locked cabinet = encryption at rest · **the armoured van =** encryption in transit · **a clerk reading a file at the desk =** an authorised query, which neither lock stops

T TAXILA

The Data Protection Officer asks whose data the SIS holds and who can read it.

Common mistakes

× COMMON MISTAKE

The from line proves who sent the mail.

Anyone can write it; the three checks and the header tell the truth.

× COMMON MISTAKE

SPF, DKIM and DMARC make phishing impossible.

A look-alike domain can pass its own checks.

× COMMON MISTAKE

The application needs full database rights to work.

It needs only the reads and writes its job requires.

Back to the Registrar message

Which of today's controls would have held last semester's message, and which would have limited the harm from the two passwords that were given away?

Before the next day

READ	**Security in Computing, sections 4.5 and 9.6** Email and message attacks and security; then chapter 7, sections 7.1 to 7.4, on databases.
PRACTICE	**A microfinance cooperative's app** Practice question 7: email authentication, database least privilege, a controller's duty.
TASK	**Your group's controls map** Add today's email and database controls to your group's register. *No evidence pack today.*

Questions & Discussion

This afternoon: trace a suspect header, then scope a database account and read its log.



Disclaimer & Copyright

The information in this presentation is for general teaching purposes only. It is not comprehensive and is not professional advice; any reliance you place on it is at your own risk. I aim to keep it accurate, but I make no representations or warranties of any kind about its completeness, accuracy, reliability or suitability.

Security tools, standards and laws change. Versions, editions and commencement dates in this presentation were checked at the time of writing; check the current documentation before relying on them.

This presentation may refer to third-party websites or content. I do not endorse their views or information, and I am not responsible for their content.

Taxila College is fictional. Its campuses, people, systems and incidents were invented for teaching. Product and tool names, for example Kali Linux, VirtualBox, CyberChef and Wireshark, belong to their owners; this material is not affiliated with or endorsed by any of them.

Practise only on your own virtual machine, the module's provided files and application, and the portal's demos. Testing a system you do not own, without written permission, is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007.

© Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content under CC BY-NC-SA 4.0; code and demonstrations under MIT; Open Sans under the SIL Open Font Licence.

Revision fa5daf6